

Intercept the request

Untitled Session - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites

- GET:HttpBasics.lesso
- HttpProxies
- GET:HttpProxies.lesso
- GET:WebGoatIntroduc
- GET:WebWolfIntroduc
- challenge
 - GET:logo
- fonts
- images
 - GET:boss.jpg
 - GET:burpfilter.png
 - GET:burpfilterclient.pn

Method: POST Header: Text Body: Text

POST http://127.0.0.1:8080/WebGoat/challenge/1 HTTP/1.1

Host: 127.0.0.1:8080

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

Accept: */*

Accept-Language: en-US,en;q=0.5

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

X-Requested-With: XMLHttpRequest

Content-Length: 31

Origin: http://127.0.0.1:8080

Connection: keep-alive

username=admin&password=aaaaaa

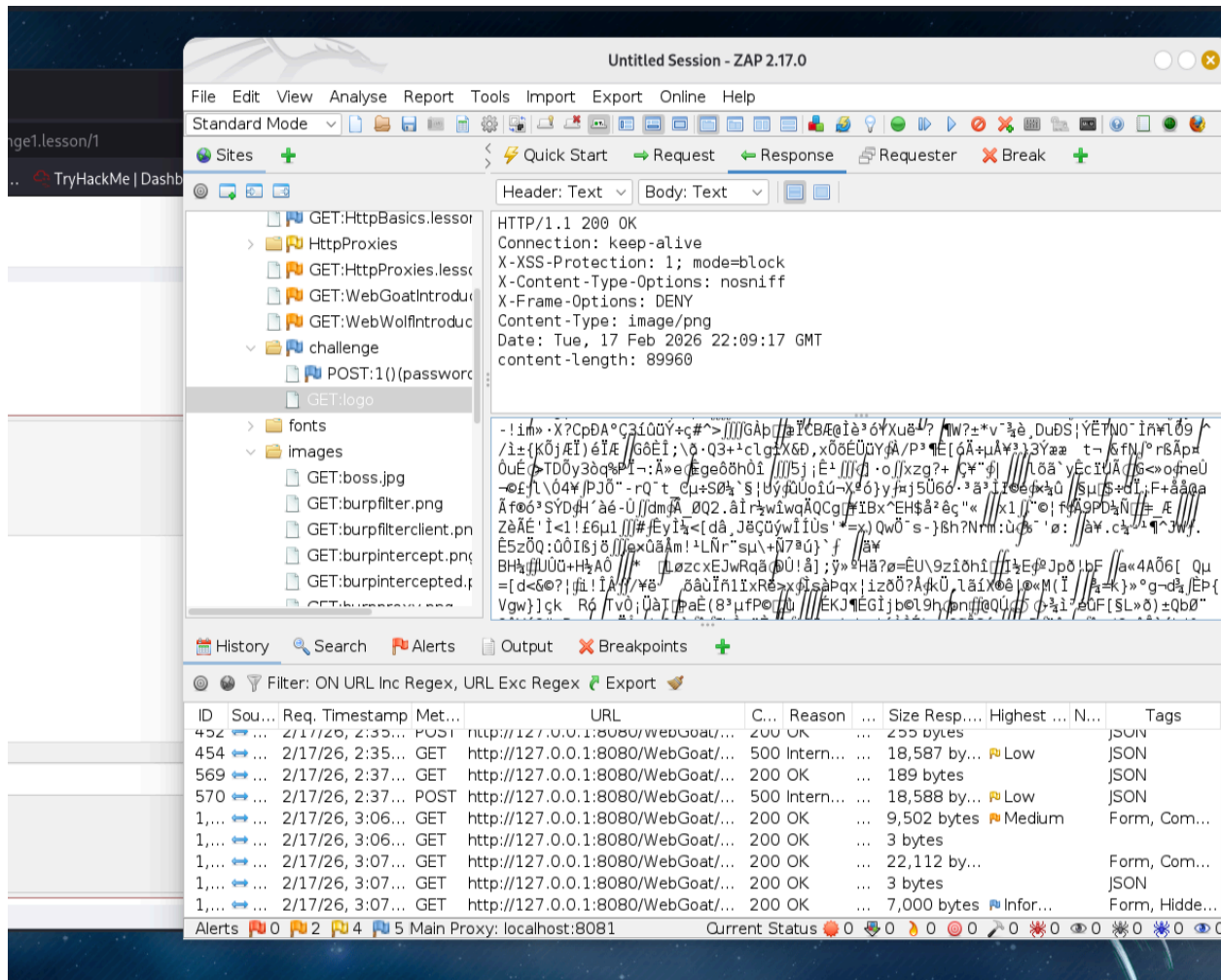
History Search Alerts Output Breakpoints

Filter: ON URL Inc Regex, URL Exc Regex Export

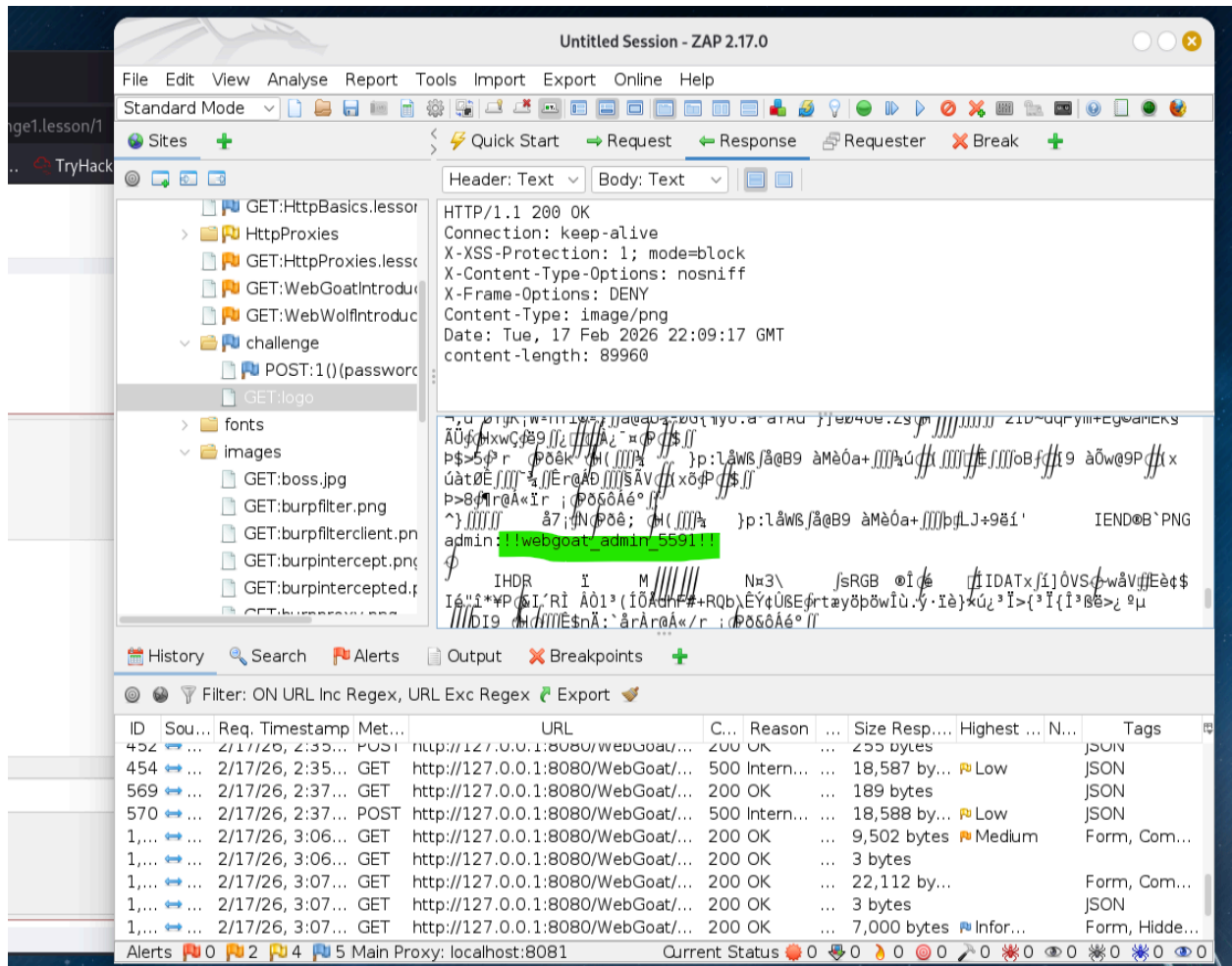
ID	Source	Req. Timestamp	Met...	URL	C...	Reason	Size Resp...	Highest ...	N...	Tags
204	...	2/17/26, 2:24...	GET	http://127.0.0.1:8080/webgoat/...	200	OK	3 bytes			JSON
452	...	2/17/26, 2:35...	POST	http://127.0.0.1:8080/WebGoat/...	200	OK	255 bytes			JSON
454	...	2/17/26, 2:35...	GET	http://127.0.0.1:8080/WebGoat/...	500	Intern...	18,587 by...	Low		JSON
569	...	2/17/26, 2:37...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	189 bytes			JSON
570	...	2/17/26, 2:37...	POST	http://127.0.0.1:8080/WebGoat/...	500	Intern...	18,588 by...	Low		JSON
1,...	...	2/17/26, 3:06...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	9,502 bytes	Medium		Form, Com...
1,...	...	2/17/26, 3:06...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	3 bytes			
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	22,112 by...			Form, Com...
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	3 bytes			JSON
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	7,000 bytes	Infor...		Form, Hidde...
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	299 bytes			
1,...	...	2/17/26, 3:09...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	4,274 bytes			Form, Pass...
1,...	...	2/17/26, 3:09...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	3 bytes			JSON

Alerts 0 2 4 5 Main Proxy: localhost:8081 Current Status 0 0 0 0 0 0 0 0 0 0 0 0

Change the response on the logo asset to text



Locate the password in the text:



Enter the password or forward with ZAP to retrieve the flag

Untitled Session - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites Quick Start Request Response Requester Break

Method Header: Text Body: Text

GET:HttpBasics.lesso
 > HttpProxies
 GET:HttpProxies.lesse
 GET:WebGoatIntrodu
 GET:WebWolfIntroduc
 > challenge
 POST:10(password
 GET:logo
 > fonts
 > images
 GET:boss.jpg
 GET:burpfilter.png
 GET:burpfilterclient.pn
 GET:burpintercept.png
 GET:burpintercepted.p
 GET:burpintercepted.p

POST http://127.0.0.1:8080/WebGoat/challenge/1 HTTP/1.1
 Host: 127.0.0.1:8080
 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
 Accept: */*
 Accept-Language: en-US,en;q=0.5
 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
 X-Requested-With: XMLHttpRequest
 Content-Length: 46
 Origin: http://127.0.0.1:8080
 Connection: keep-alive
 Referer: http://127.0.0.1:8080/WebGoat/start.mvc
 Cookie: JSESSIONID=gP5m1ewpNKqXL_BiWldUYesRUE8waVhuIa2Qjx11

username=admin&password=!!webgoat_admin_5591!!

History Search Alerts Output Breakpoints

Filter: ON URL Inc Regex, URL Exc Regex Export

ID	Sou...	Req. Timestamp	Met...	URL	C...	Reason	...	Size Resp...	Highest ...	N...	Tags
452	...	2/17/26, 2:35...	POST	http://127.0.0.1:8080/webGoat/...	200	OK	...	255 bytes			JSON
454	...	2/17/26, 2:35...	GET	http://127.0.0.1:8080/WebGoat/...	500	Intern...	...	18,587 by...	Low		JSON
569	...	2/17/26, 2:37...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	...	189 bytes			JSON
570	...	2/17/26, 2:37...	POST	http://127.0.0.1:8080/WebGoat/...	500	Intern...	...	18,588 by...	Low		JSON
1,...	...	2/17/26, 3:06...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	...	9,502 bytes	Medium		Form, Com...
1,...	...	2/17/26, 3:06...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	...	3 bytes			
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	...	22,112 by...			Form, Com...
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	...	3 bytes			JSON
1,...	...	2/17/26, 3:07...	GET	http://127.0.0.1:8080/WebGoat/...	200	OK	...	7,000 bytes	Infor...		Form, Hidde...

Alerts 0 0 2 4 5 Main Proxy: localhost:8081 Current Status 0 0 0 0 0 0 0 0 0 0 0 0

Flag: 06342b52-120b-4d24-b41e-9c7d3a0fe1e5

WebGoat

127.0.0.1:8080/WebGoat/start.mvc#lesson/Challenge1.lesson/1

cyber Wikipedia, the free en... NASA Science Dashboard Student Hub - MSU De... TryHackMe | Dashboard Dashboard | Web Secu... Other Bookmarks

WEBGOAT

Introduction >

General >

(A1) Injection >

(A2) Broken Authentication >

(A3) Sensitive Data Exposure >

(A4) XML External Entities (XXE) >

(A5) Broken Access Control >

(A7) Cross-Site Scripting (XSS) >

(A8) Insecure Deserialization >

(A9) Vulnerable Components >

(A8:2013) Request Forgeries >

Client side >

Challenges >

Admin lost password

Without password

Admin password reset

Without account

Admin lost password

Reset lesson

1 2

WEBGOAT

Username

admin

Password

Password

Sign in

06342b52-120b-4d24-b41e-9c7d3a0fe1e5

Submit flag

Congratulations, you solved the challenge. Here is your flag: 06342b52-120b-4d24-b41e-9c7d3a0fe1e5